

アクセス制御ポリシー

1. 文書管理

本文書は当行の情報システムにおけるアクセス制御の方針および実施基準を定めるものである。文書番号は ISP-002 とし、情報セキュリティポリシー (ISP-001) の下位文書として位置づける。

本版は第3.1版 (2025年6月1日改定) であり、前版 (第3.0版、2025年1月1日) からの主な変更点は、特権アクセス管理 (PAM) の導入要件追加およびAPI認証に関する条項の新設である。FISC安全対策基準 技-13 (アクセス制御方針の策定) に準拠する。

本文書の管理責任者は情報システム部長とし、年1回以上の見直しを実施する。関連文書として情報セキュリティポリシー (ISP-001) 第9章「アカウント管理」およびデータ保護ポリシー (ISP-004) を参照のこと。

2. 基本原則

アクセス制御の基本原則として、最小権限の原則 (Principle of Least Privilege) を採用する。利用者には業務遂行に必要な最小限の権限のみを付与し、不要な権限の保有を排除する。FISC安全対策基準 技-14 (アクセス権の最小化) に基づき、全システムで統一的に適用する。

職務分掌 (Separation of Duties) の原則に基づき、相互牽制が必要な業務については単一の利用者に権限が集中しないよう制御する。特に、取引の起票と承認、システム開発と本番環境への適用、セキュリティ設定の変更と監査の各業務は異なる担当者が実施する。

Need to Know の原則を適用し、業務上知る必要のない情報へのアクセスを制限する。データ分類に基づくアクセス制御の詳細はデータ保護ポリシー (ISP-004) 第2章を参照のこと。全システムのアクセスはデフォルト拒否 (Deny by Default) とし、明示的に許可された操作のみ実行可能とする。

3. RBAC設計

アクセス制御方式として、ロールベースアクセス制御 (RBAC: Role-Based Access Control) を標準として採用する。FISC安全対策基準 技-15 (利用者認証とアクセス制御の実装) に基づき、業務ロールと情報システムの権限を適切に対応付ける。

ロール設計は、組織構造 (部・課・チーム) と業務機能 (取引処理、照会、管理、監査等) の二軸で体系化する。1つのロールに付与する権限数は原則50以下とし、権限の肥大化を防止する。ロール階層は最大4階層 (組織ロール→業務ロール→機能ロール→データロール) とし、継承関係を明確に定義する。

RBAC設計の変更は、情報セキュリティ委員会の承認を経て実施する。新規業務ロールの追加時には、既存ロールとの権限重複・矛盾がないことを検証する。ABAC (Attribute-Based Access Control) の導入は、コンテキスト依存の制御が必要な領域 (時間帯制限、アクセス元制限等) に限定して段階的に進める。

4. ロール定義と権限マトリクス

主要な業務ロールとして以下を定義する。「一般行員」は自部署の顧客情報照会および取引起票権限を持つ。「係長・主任」は一般行員の権限に加え、取引承認（1,000万円未満）権限を持つ。「課長」は取引承認（1億円未満）および部下のアクセス権申請承認の権限を持つ。

「システム運用担当」は本番環境の監視・運用操作権限を持つが、データの直接参照・変更は不可とする。「システム開発担当」は開発環境・テスト環境のフルアクセス権限を持つが、本番環境へのアクセスはデプロイパイプラインを通じた間接的なもののみとする。「DBA」はデータベースの構造変更権限を持つが、個人情報を含むデータの直接参照には追加の承認手続きを要する。

「監査担当」は全システムの読み取り専用アクセス権限を持ち、変更操作の権限は一切付与しない。「セキュリティ管理者」はセキュリティ設定の変更権限を持つが、業務データへのアクセス権限は持たない。権限マトリクスは情報システム部が管理し、四半期ごとに最新の状態を維持する。

5. 特権アクセス管理

管理者権限（root、Administrator、DBA等）を持つ特権アカウントは、特権アクセス管理（PAM: Privileged Access Management）システムにより一元管理する。FISC安全対策基準 技-18（特権ID管理）に準拠し、特権の不正利用を防止する。

特権アクセスはJIT（Just-In-Time）方式を採用し、必要な時間帯のみ一時的に権限を付与する。1回のJITセッションは最大4時間とし、延長には再承認を要する。特権アクセスの申請には業務上の理由の明記と、上長およびセキュリティ管理者の二重承認を必要とする。緊急時のブレイクグラス手順では、事後24時間以内の承認取得を必須とする。

全ての特権操作はPAMシステムにより操作画面の録画およびコマンドログの記録を実施する。録画データは暗号化の上、最低1年間保存する。特権アカウントのパスワードはPAMシステムが自動的にローテーションし、情報セキュリティポリシー（ISP-001）第7章の特権パスワード要件を適用する。

特権アカウントの利用状況は月次でレビューし、不審な利用パターンがないか確認する。特権アカウントへの多要素認証は必須とし、ハードウェアトークンによる認証を要求する。

6. アカウントライフサイクル

アカウントのライフサイクル管理は、プロビジョニング（作成）、変更、無効化、削除の各フェーズで適切な承認プロセスを経て実施する。人事システムとの連携により、入社・異動・退職に伴うアカウント操作を自動化する。

新規アカウント作成は、所属部署長の承認後、原則として申請日から2営業日以内に完了する。付与するロールは申請内容に基づき、過剰な権限が付与されないことを情報システム部が確認する。異動時には、異動元の権限を速やかに削除し、異動先の業務に必要な権限を新たに付与する。

退職時のアカウント処理は情報セキュリティポリシー（ISP-001）第9章に定める手順に従い、退職日当日中に全アカウントを無効化する。委託先要員のアカウントは契約期間満了日に自動無効化されるよう、有効期限を設定する。休職者のアカウントは休職開始日に無効化し、復職時に再有効化する。

7. API・サービスアカウント

システム間連携に使用するAPIアカウントおよびサービスアカウントは、個人アカウントとは区別して管理する。各サービスアカウントには管理責任者（個人）を明確に割り当て、責任の所在を明確にする。FISC安全対策基準

技-19（システム間接続の認証）に準拠した認証方式を採用する。

API認証にはOAuth 2.0 Client Credentials フローまたは相互TLS認証（mTLS）を使用する。APIキーによる認証は新規システムでは禁止し、既存システムは2026年3月末までにOAuth 2.0へ移行する。APIアクセスにはレート制限を設定し、異常なアクセスパターンを検知・遮断する。

サービスアカウントのクレデンシャルは、暗号化基準（ISP-003）に定める方式で保護する。ソースコード内へのクレデンシャル埋め込みを禁止し、シークレット管理サービス（HashiCorp Vault等）を使用する。サービスアカウントの棚卸しは四半期ごとに実施し、不要なアカウントを削除する。

8. アクセス権棚卸し

全利用者のアクセス権棚卸しを四半期ごと（4月、7月、10月、1月の各月末まで）に実施する。棚卸しは各部署の情報セキュリティ推進担当者が実施し、部署長が確認・承認する。FISC安全対策基準 運-20（アクセス権の定期見直し）に準拠した運用とする。

棚卸しの対象は、業務アプリケーション、ファイルサーバ、データベース、クラウドサービス、特権アカウントの全てを含む。棚卸し結果として不要と判定された権限は、判定日から5営業日以内に削除する。是正率（不要権限の削除完了率）は95%以上を目標とし、月次で進捗を管理する。

棚卸し結果は情報セキュリティ委員会に報告し、傾向分析（権限の肥大化傾向、異動後の権限残存等）を実施する。年1回の内部監査においてもアクセス権の妥当性を検証し、棚卸しプロセス自体の有効性を評価する。

9. 退職・異動時対応

退職・異動時のアクセス権処理は、人事情報の確定から原則として即日対応する。人事システムとID管理システムを連携させ、人事異動の確定をトリガーとした自動処理を実現する。FISC安全対策基準 運-21（退職者のアクセス権の無効化）に準拠した即時対応体制を確保する。

退職時には全てのアカウントの無効化に加え、VPNアクセス証明書の失効、物理入退室カードの回収、多要素認証デバイスの回収を退職日当日中に完了する。退職者が利用していた共有パスワード（あれば）は速やかに変更する。リモートアクセス環境の無効化についてはリモートアクセスポリシー（ISP-005）も参照のこと。

部署異動時には、異動元部署のアクセス権を異動日から5営業日以内に全て削除する。引き継ぎ期間中に旧部署のデータへのアクセスが必要な場合は、期間限定（最大30日）の一時アクセス権を申請により付与する。異動処理の完了状況は情報システム部が月次でモニタリングし、遅延案件をフォローアップする。